

ECOM EXPERTS

Ecom captchaent

Manual de usuario, tecnico y de desarrollo

ecom_captchaent 1.1.6 · 07/09/2026

Contenido

1. Introducción

2. Frontend (Cliente)

Funcionamiento:

3. Backend (Servidor)

Proceso de Validación en el Módulo:

4. Configuración

Configuración del Desafío (Score vs Checkbox)

5. Acciones (Actions)

6. Funcionalidades Avanzadas de Defensa

Account Defender (Defensor de Cuentas)

Fraud Prevention (Prevención de Fraude)

SMS Defense (Defensa SMS)

Password Leak Defense (Defensa de Contraseñas Filtradas)

Autenticación de Varios Factores (MFA)

7. Solución al Aviso: "No se creó ninguna evaluación este mes"

Este documento explica en detalle el funcionamiento, configuración y capacidades de **Google reCAPTCHA Enterprise**, así como su integración específica en este módulo para PrestaShop.

1. Introducción

reCAPTCHA Enterprise es mucho más que un simple "Check" de "No soy un robot". Es una plataforma de seguridad integral que analiza el comportamiento, el entorno y el contexto del usuario para asignar una puntuación de riesgo (`score`) o proteger contra ataques específicos (robo de cuentas, fraude de pagos).

A diferencia de la versión v3 gratuita, Enterprise ofrece: - **Puntuaciones detalladas** y códigos de razón para el riesgo. - **Account Defender**: Protección específica para login/registro. - **Fraud Prevention**: Protección para pagos. - **SLA y Soporte** (en planes de pago).

2. Frontend (Cliente)

En el *frontend* (navegador del usuario), el módulo carga el script oficial de Enterprise.

Funcionamiento:

1. **Carga del Script**: Se inyecta `enterprise.js` con la `Site Key`.
 2. **Generación de Token**:
 - **Score-based (Invisible)**: Se ejecuta `grecaptcha.enterprise.execute()` con una **acción** específica (ej. 'contact', 'login'). Esto genera un token encriptado que contiene información sobre la interacción del usuario.
 - **Checkbox**: Se renderiza el widget visible. Al pulsarlo, Google genera el token.
 3. **Envío**: El token se inserta en un campo oculto (`recaptcha_token`) dentro del formulario y se envía al servidor junto con los datos del usuario.
-

3. Backend (Servidor)

El *backend* es donde ocurre la magia real. Recibir un token no es suficiente; hay que **verificarlo** creando una "Evaluación" (`Assessment`).

Proceso de Validación en el Módulo:

1. **Recepción**: El módulo intercepta el envío del formulario (Hook `actionSubmit...`).
2. **Llamada a la API**: Usa tus credenciales (Project ID, API Key) para enviar el token a `https://recaptchaenterprise.googleapis.com/.../assessments` .
 - *Nota*: Aquí es donde desaparece el aviso de "No se han creado evaluaciones".
3. **Análisis**:
 - Verifica si el token es válido.

- Verifica si la **Acción** coincide (ej. el token fue creado para 'login' y se está usando en 'login').
- Obtiene el **Score** de riesgo (0.0 a 1.0).

4. **Decisión:** Si el score es menor al umbral configurado (ej. 0.5), el módulo bloquea la petición y muestra un error.

4. Configuración

Para que el sistema funcione, necesitas 3 datos críticos de Google Cloud Console:

1. **Project ID:** El identificador único de tu proyecto en Google Cloud.
2. **Site Key (Clave del sitio):** La clave pública que va en el HTML.
 - *Importante:* Debe ser de tipo "Enterprise" (Puntuación o Casilla de verificación).
3. **API Key:** Una credencial de API con permisos para `reCAPTCHA Enterprise API`.

Configuración del Desafío (Score vs Checkbox)

- **Score (Puntuación):** Invisible para el usuario. Google devuelve un número (0.0 a 1.0). Tú decides el corte.
 - *Ventaja:* Sin fricción.
 - *Desventaja:* Requiere ajuste fino del umbral.
 - **Checkbox (Casilla):** El usuario debe hacer clic. Si es sospechoso, Google le pone un reto visual.
 - *Ventaja:* Bloqueo duro inmediato.
 - *Desventaja:* Molesta al usuario.
-

5. Acciones (Actions)

Las "Acciones" son etiquetas que dan contexto a Google sobre qué está haciendo el usuario. Son vitales para que la IA aprenda el comportamiento normal en cada sección.

- `contact` : Envío de formulario de contacto.
- `login` : Inicio de sesión.
- `signup` : Registro de nueva cuenta.
- `newsletter` : Suscripción a boletines.
- `checkout` : Proceso de pago.

¿Por qué son importantes? Si un atacante obtiene un token válido visitando tu *Home* (acción `homepage`) e intenta usarlo para registrarse masivamente (acción `signup`), el módulo detectará la **Discrepancia de Acción** y bloqueará el ataque, incluso si el token es técnicamente válido.

6. Funcionalidades Avanzadas de Defensa

Account Defender (Defensor de Cuentas)

Protege contra **ATO (Account Takeover)** y creación de cuentas falsas. * **Cómo funciona:** El módulo envía un *identificador hashado* (anónimo) del usuario (normalmente el email) a Google durante el login o registro. *

Qué detecta: * Intentos de login masivos desde una IP a múltiples cuentas. * Credenciales robadas probadas en tu sitio. * Creación masiva de cuentas desde patrones sospechosos. * **Configuración:** Requiere activar "Related Accounts" en Google Cloud y el interruptor "Enable Account Defender" en el módulo.

Fraud Prevention (Prevención de Fraude)

Protege contra fraudes en pagos, como el "Card Testing" (probar tarjetas robadas). * **Cómo funciona:** Se envían datos de la transacción (monto, ítems, dirección de envío - *futura implementación*) al evaluar el token en el checkout. * **Beneficio:** Detecta patrones de fraude financiero que un simple captcha no vería.

SMS Defense (Defensa SMS)

Capacidad de la plataforma (No implementada por defecto en este módulo web): Protege contra el bombeo de tráfico SMS (SMS pumping) en apps que verifican teléfonos, evitando costes excesivos en gateways de SMS.

Password Leak Defense (Defensa de Contraseñas Filtradas)

Google comprueba si las credenciales (usuario/contraseña) usadas en tu sitio han aparecido en filtraciones masivas de datos en la web oscura. Si es así, te avisa para que obligues al usuario a cambiar su contraseña. * *Requiere integración profunda en el proceso de autenticación.*

Autenticación de Varios Factores (MFA)

Enterprise permite disparar retos de MFA (enviar un código al correo/SMS) directamente desde la evaluación de riesgo si el score es dudoso, actuando como una capa intermedia antes de dejar pasar al usuario.

7. Solución al Aviso: "No se creó ninguna evaluación este mes"

Si ves este mensaje en tu panel de Google Cloud:

"No assessment was created this month, so your site might be at risk."

Significa que: Tienes la clave puesta en tu web (Frontend), pero tu servidor (Backend) **NO** está preguntando a Google si los tokens son válidos. Solo estás generando tokens, no validándolos.

La Solución: Este módulo soluciona eso automáticamente. Cada vez que alguien envía un formulario: 1. El módulo coge el token. 2. Llama a la API `projects.assessments.create`. 3. **Esta llamada es la "Evaluación" (Assessment).**

Una vez que instales y configures el módulo correctamente y recibas el primer envío de formulario real o de prueba, ese aviso desaparecerá en 24-48 horas y verás gráficas de tráfico y riesgo en tu consola.